

06 — Exam Traps, Numbers, and Stale Answers

Read this the night before. Nothing new here — only the things people get wrong.

1. Numbers to memorise

Subnets

Subnet	Required name	Minimum size
Azure Firewall	AzureFirewallSubnet	/26
Azure Firewall management (forced tunnelling)	AzureFirewallManagementSubnet	/26
Bastion	AzureBastionSubnet	/26
VPN / ExpressRoute Gateway	GatewaySubnet	/29 (use /27)
Application Gateway	any name, dedicated	/24 recommended

Azure smallest usable subnet	—	/29 (Azure reserves 5 IPs per subnet)
------------------------------	---	--

Limits and durations

Thing	Value
NSG rule priority range	100–4096
NSG default rule priorities	65000, 65001, 65500
Custom RBAC roles per tenant	5,000 (2,000 China/Gov)
Role assignments per subscription	4,000 (2,000 per management group)
Management group nesting depth	6 levels below root
Key Vault soft delete retention	7–90 days (default 90)
Key Vault access policy entries per vault	1,024
Blob/container soft delete retention	1–365 days
Stored access policies per container	5
User delegation SAS max lifetime	7 days
Client secret max lifetime	24 months
PIM activation max duration	1–24 hours (default 8)
JIT default max request time	3 hours
Locked retention policy — extensions allowed	5 times , never shortened

Defender plan trial	30 days , cannot pause or extend
Defender for Servers P2 free ingestion	500 MB/day
Sentinel free retention (Analytics)	90 days (Sentinel-enabled workspaces); archive to 12 years
Sentinel NRT rule frequency	1 minute
Scheduled rule frequency / lookback range	5 minutes – 14 days
Azure Policy evaluation cycle	~24 hours
Firewall Standard / Premium throughput	30 Gbps / 100 Gbps
DDoS Network Protection plan coverage	100 public IPs included
Exam pass score	700

2. The ten traps that catch most people

1. Global Administrator ≠ Azure access. A Global Admin sees no subscriptions until they **elevate access** (root scope /, becoming User Access Administrator). Conversely, Subscription Owner grants nothing in Entra ID.

2. Private Endpoint without DNS does nothing. The endpoint exists, the NIC exists, and traffic still goes to the public IP because the FQDN resolves publicly. You need the **privatelink.* Private DNS zone** linked to the VNet.

3. Service Endpoints do not work from on-premises. Any stem mentioning ExpressRoute, VPN, branch offices, or "our datacentre" rules out Service Endpoints.

4. Dynamic Data Masking is not encryption. It masks the **result set**.

A user who can query the table can still infer values with `WHERE`. For "protect from DBAs" the answer is **Always Encrypted**.

5. VNet peering is not transitive. Spoke-to-spoke does not work through a hub peering alone. You need UDRs pointing at a hub NVA/Firewall, or an AVNM connectivity configuration.

6. Policy Deny and Modify only affect new/updated resources. Fixing what already exists requires **DeployIfNotExists/Modify + a remediation task** — and the assignment's **managed identity** needs the right RBAC or it silently fails.

7. NSGs allow all VNet traffic by default, including across peerings. `AllowVnetInBound` (65000) covers the whole `VirtualNetwork` service tag, which includes peered VNets and on-prem ranges advertised via BGP. Microsegmentation needs explicit deny rules.

8. "Allow Azure services and resources to access this server" is not a security control. On Azure SQL it is the `0.0.0.0` rule and permits **any** Azure resource in **any** tenant. Least-privilege answers always turn it off.

9. Purge protection is one-way. Soft delete can be configured; **purge protection, once enabled, can never be disabled** for that vault. Same for **locking** an immutable vault or a time-based retention policy.

10. Security defaults and Conditional Access are mutually exclusive. If a scenario needs granular CA, security defaults must be disabled first. And CA requires **P1**; risk-based policies and PIM require **P2**.

Five more worth an extra look

- **Key Vault Reader cannot read secret values** — that is `Key Vault Secrets User`.
- **A Sentinel Responder cannot run a playbook** without `Logic App Contributor`, and Sentinel itself needs `Microsoft Sentinel Automation Contributor` on the playbook's RG.
- **Anomaly rules generate no alerts and no incidents** — they write to the `Anomalies` table.

- **Infrastructure encryption on a storage account cannot be enabled after creation.**
 - **Resource locks are control plane only.** A `ReadOnly` lock on a storage account does not stop blob data writes.
-

3. Where older study material is now wrong

The exam is written to the **22 January 2026** skills outline, but many practice banks and courses predate the changes below. Know the current answer; recognise the old one.

Topic	Stale answer	Current reality
Defender for Servers agent	"Install the Log Analytics agent (MMA)"	MMA is retired. Defender for Servers uses agentless scanning + Defender for Endpoint for most features. AMA remains only for the 500 MB ingestion benefit
Defender for Servers P2 features	Adaptive application controls, adaptive network hardening	No longer in the plan feature table — treat as legacy
Defender for DNS	A standalone plan	Deprecated — DNS alerts folded into Defender for Servers Plan 2
Defender for AKS / Defender for Container Registries	Separate plans	Deprecated → Defender for Containers

Defender for Key Vault / Resource Manager	Per-transaction plans	Legacy per-transaction plans deprecated → fixed pricing model ; capabilities remain
Defender for Cloud recommendations	Grouped recommendations / sub-assessments	Individual recommendations ; grouped ones removed from the Azure portal 31 July 2026
Defender for Cloud "disable rule"	Disable a recommendation rule	Exemptions (Waiver / Mitigated)
Sentinel portal	Managed in the Azure portal	Moving to the Microsoft Defender portal . New environments created there from 1 July 2026 ; Azure portal support ends 31 March 2027
Sentinel Microsoft security + Fusion rules	Always available	Auto-disabled when Defender XDR incident integration is on or Sentinel is in the Defender portal — XDR creates incidents instead
Sentinel detections	Analytics rules only	Custom detections in the Defender portal are now Microsoft's recommended unified path
Sentinel TI ingestion	Legacy TI Indicators API	Threat Intelligence Upload API (Graph-based)

Azure AD naming	Azure AD, Azure AD Premium P1/P2	Microsoft Entra ID, Microsoft Entra ID P1/ P2. Exam uses Entra naming — but recognise both
Azure AD Domain Services	—	Microsoft Entra Domain Services
Pod-managed identity (AKS)	Use AAD Pod Identity	Deprecated → Microsoft Entra Workload ID (workload identity federation)
Key Vault access model	Access policies are the default	Azure RBAC is recommended; access policies are legacy and do not support PIM
Azure Blueprints	Use blueprints for governance	Deprecated → Azure Policy + Template Specs / Deployment Stacks
NSG flow logs	The way to log flows	On a retirement path → VNet flow logs
Azure Security Center / Azure Defender	—	Microsoft Defender for Cloud
MFA on Azure management	Optional	Mandatory — Phase 1 (portal) and Phase 2 (CLI, PowerShell, IaC, control-plane REST for create/update/delete) since 1 Oct 2025 ; deferrals expired 1 July 2026

Front Door + CDN	Separate products	Azure Front Door Standard/Premium absorbed the CDN offering
------------------	-------------------	--

How to answer when old and new conflict: the exam is authored against Microsoft Learn documentation. Pick the **currently documented** answer. If both a retired feature and its replacement appear as options, the replacement is correct.

4. Terminology pairs that are easy to swap

A	B	Difference
Authentication	Authorization	Who you are / what you may do
Azure RBAC	Entra roles	Azure resources / directory objects
Actions	DataActions	Control plane / data plane
NotActions	Deny assignment	Subtracts from one role / overrides all allows
Eligible	Active	Must activate / usable now (PIM)
Delegated permission	Application permission	On behalf of a user / app-only, admin consent required
Application object	Service principal	Global definition (home tenant) / local instance (per tenant)
System-assigned MI	User-assigned MI	1:1, dies with resource / many:many, standalone

Security defaults	Conditional Access	Free, all-or-nothing / P1, granular
Sign-in risk	User risk	This request / this account — MFA vs password change
NSG	ASG	Rule container / NIC grouping used inside rules
Network rule	Application rule	L3/L4 IP-port / FQDN and URL — network rules processed first
Service Endpoint	Private Endpoint	Public IP over backbone, free / private IP, on-prem capable, paid
Private Link	Private Link Service	The technology / publishing your own service
Detection mode	Prevention mode	WAF logs only / WAF blocks
Audit	Deny	Policy records / Policy blocks
AuditIfNotExists	DeployIfNotExists	Flags the missing thing / creates it
SSE	ADE	Platform storage-level / guest-OS BitLocker-dm-crypt
TDE	Always Encrypted	At rest, server-side / column, client-side, hides from DBAs
Deterministic	Randomised	Always Encrypted: equality queries possible / stronger, no equality

Soft delete	Purge protection	Recoverable window / cannot purge during it, irreversible once on
Account SAS	Service SAS	Multi-service + account ops / single service
User delegation SAS	Service SAS	Entra-signed, blob, ≤ 7 days / key-signed
Time-based retention	Legal hold	Fixed period / until explicitly cleared
Secure Score	Regulatory compliance	MCSB-driven posture number / pass-fail against standards
Foundational CSPM	Defender CSPM	Free score and recommendations / attack paths, explorer, agentless, governance rules
CSPM	CWPP	Posture — are we configured right / protection — are we under attack
Workflow automation	Automation rule	Defender for Cloud alert/ recommendation trigger / Sentinel incident trigger
Automation rule	Playbook	Sentinel-native handling and ordering / Logic App doing the external action
Alert	Incident	Single detection / case file of related alerts
Scheduled rule	NRT rule	5 min – 14 days / every 1 minute

Fusion	Anomaly	Correlates across products into incidents / baselines behaviour, no alerts
Diagnostic settings	Data collection rule	Azure resource logs / VM guest telemetry via AMA
JIT	Bastion	Time-limited port opening, IP stays / no public IP at all
DDoS Network Protection	DDoS IP Protection	Per-VNet plan, Rapid Response + cost protection / per-IP, neither
MACsec	IPsec	L2, ExpressRoute Direct only / L3, end-to-end, any circuit

5. Ten-minute pre-exam recall list

Say each answer out loud before you walk in:

1. Azure RBAC vs Entra roles — and how a Global Admin gets Azure access → **elevate access**
2. Eligible vs active in PIM; PIM = **P2**, Conditional Access = **P1**
3. Sign-in risk → **MFA**; user risk → **password change**
4. System-assigned dies with the resource; user-assigned is shared
5. Application permissions **always** need admin consent
6. NSG defaults: inbound internet **denied**, outbound internet **allowed**, VNet **allowed**
7. Firewall order: **DNAT** → **Network** → **Application**; Premium adds **TLS inspection, IDPS, URL filtering**
8. Private Endpoint = private IP + **Private DNS zone** + works from on-prem. Service Endpoint = free, subnet-scoped, **not** from on-prem
9. WAF: **Detection** first, then **Prevention**; false positive →

exclusion

10. Encryption at host covers **temp disk and cache**; ADE is **guest-side** and needs `EnabledForDiskEncryption`
11. User delegation SAS = **Entra-signed, blob only, 7 days max**; revocable SAS = **stored access policy**
12. Locked time-based retention: extend up to **5 times**, never shorten
13. **Always Encrypted** hides data from DBAs; **DDM** hides nothing, it only masks
14. Policy: **Deny** prevents, **DINE/Modify** need a managed identity and a **remediation task** for existing resources
15. Key Vault: soft delete **7–90 days**, **purge protection is irreversible**, **RBAC over access policies**, Premium = **FIPS L2**, Managed HSM = **FIPS L3**
16. Secure Score comes from **MCSB**; a control scores only when **all** its resources are healthy
17. Defender for Servers **P2** = JIT, FIM, agentless scanning, MDVM premium, network map, **500 MB/day**
18. Defender for Servers uses **agentless + MDE**, not MMA/AMA
19. Sentinel rules: Scheduled, **NRT (1 min)**, **Anomaly (no alerts)**, Microsoft security, Fusion, TI, ML behaviour
20. **Automation rule** = Sentinel incident trigger; **playbook** = Logic App action; **workflow automation** = Defender for Cloud trigger
21. **Entity mapping** is what makes the investigation graph work
22. Sentinel Azure portal ends **31 March 2027**; XDR integration disables **Microsoft security** and **Fusion** rules